CYBERSECURITY INTERNSHIP PRACTICAL LAB REPORT

Day 04: Vishing & Smishing Attack Simulation & Telephony Defense Architecture

Engineering an Enterprise-Grade Interactive CLI Threat Progression Suite Across 10 Critical Industry Sectors

INTERNSHIP TRACK: Social Engineering Attack Simulations	**DATE OF EXECUTION:** October 23, 2026
INTERN / RESEARCHER: Md Peer Siddiqui	**TARGET REPOSITORY:** PEER-S-Vish-Smish-Simulator
HOST ORGANIZATION: Sqrock IT Solution	**GITHUB:** github.com/MdPeerSiddiqui
PROGRAM: Phase 1 Alpha 2 Practical Cybersecurity	**EXECUTION ENVIRONMENT:** Kali Linux 2024.x & Win11

1. Executive Summary & Strategic Context

Modern cybersecurity perimeters have successfully reduced the effectiveness of traditional, unauthenticated email phishing through machine-learning spam gateways, DMARC enforcement, and secure email filters. In response, sophisticated cyber-adversaries have systematically pivoted toward multi-channel telecommunications deception—specifically **Voice Phishing (Vishing)** and **SMS Phishing (Smishing)**. By exploiting VoIP Session Initiation Protocol (SIP) header malleability and rogue wholesale SMS aggregators, adversaries bypass email controls and engage human targets directly via low-latency, high-trust channels.

During **Day 04** of the Sqrock IT Solution Cybersecurity Internship, a hardened, production-grade CLI suite named **PEER'S Vish & Smish Simulator** was designed and deployed. Built without GUI overhead to guarantee deterministic execution across security platforms (including Kali Linux, Debian, macOS, and Windows), the tool provides a comprehensive framework to model, dissect, and neutralize voice and SMS social engineering attacks across **10 distinct enterprise and consumer sectors**.

2. Scope of Investigation & Technical Objectives

Objective	Target Metric / Deliverable	Verification Method
1. Multi-Sector Threat Modeling	10 fully realized scenarios spanning IT, Finance, Gov, Telecom, etc.	Schema validation in scenarios.json with 5-phase dialogue.
2. Interactive Call Roleplay	Branching voice dialogs with pre-scripted adversary counters.	Live CLI execution with Out-of-Band defense validation.
3. Psychological Trigger Scorer	Quantitative evaluation of Urgency, Authority, Fear, Scarcity, Sympathy.	0–100 trigger intensity scale with dynamic ASCII radar visualizer.
4. Mobile Smishing Forensics	GSM-7 character accounting, 160-char threshold, UDH segmentation.	Automated payload parser with domain link isolation.
5. Carrier Countermeasures	STIR/SHAKEN Level A/B/C attestation & FIDO2 token analysis.	Technical reference matrix embedded in simulator & report.
6. Quality Assurance & Tests	9 automated unit tests verifying schema, bounds, and dialogue.	Automated test runner executing in < 0.005s with 100% pass rate.

3. Telephony Exploitation Mechanics & Psychology

VoIP SIP Header Manipulation: Unlike the Public Switched Telephone Network (PSTN), modern telecommunications utilize Session Initiation Protocol (SIP RFC 3261). Adversaries register trunk accounts with unverified VoIP providers, injecting custom strings into the From: and P-Asserted-Identity headers. Consequently, endpoint mobile devices display spoofed internal helpdesk extensions or trusted corporate numbers without intrinsic cryptographic verification.

Rogue SMS Aggregators & Alphanumeric Sender IDs: In international telecommunications, SMS gateways permit alphanumeric Sender IDs (e.g., 'CARRIER-SEC' or 'SWIFT-PKG') without cryptographic origin checks. Attackers exploit these aggregators to bypass carrier filtering, injecting deceptive hyperlinks designed to harvest mobile credentials or prompt malicious application downloads.

4. The 10 Industry Attack Scenarios: Empirical Catalog

To ensure the simulator prepares defense teams for the complete threat spectrum, 10 distinct industry attack profiles were engineered into scenarios.json. Each profile establishes authentic adversary pretexting, realistic caller lines, and primary psychological attack levers:

#	Sector ID	Industry Sector	Spoofed Line / Caller ID	Exploitation Vector	Score / Risk
1	it_support	Enterprise IT	+1 (800) 555-0199 (Ext 4401)	MFA Push Token / Session Sync Theft	**80** / High
2	banking_fraud	Banking & Finance	+1 (888) 555-0144 (Fraud Desk)	Emergency Transfer to 'Safe Account'	**83** / High
3	gov_tax	Government & Tax	+1 (800) 829-1040 (Revenue Ag)	Immediate Tax Penalty Wire Settlement	**75** / High
4	parcel_delivery	Logistics & Courier	SWIFT-PKG (SMS Gateway)	Undelivered Parcel Address Redirection	**69** / Moderate
5	hr_payroll	Corporate HR	+1 (800) 555-0177 (Payroll Desk)	Direct Deposit Routing Number Reroute	**80** / High
6	healthcare_copay	Healthcare & Rx	MED-RX (Claims Dispatch)	Prescription Hold Payment Interception	**83** / High
7	executive_ceo	Executive Whaling	+1 (415) 555-0122 (CEO Mobile)	Confidential M&A; Gift Card / Wire Bypass	**84** / High
8	telecom_carrier	Telecom / Mobile	CARRIER-SEC (Fraud Division)	Port-Out / SIM Swap OTP Interception	**85** / Critical
9	ecommerce_retail	Online Retail	ORDER-ALERT (Fulfillment)	Unauthorized MacBook Charge Cancellation	**79** / High
10	utility_services	Public Utilities	+1 (800) 555-0111 (Grid Ops)	45-Minute Power Cutoff Payment Fraud	**80** / High

5. Attack Progression Phases (The 5-Stage Vishing Lifecycle)

Every scenario implements a structured 5-stage progression model: (1) **Introduction** establishing false rapport and authority; (2) **Hook** introducing an urgent operational crisis (e.g., Active Directory lockout or power cutoff); (3) **The Ask** demanding sensitive data; (4) **Pre-Scripted Objection Handling** countering target skepticism with escalated urgency or policy citations; and (5) **Exit Strategy** ending the call cleanly before suspicion solidifies.

6. Empirical Verification & Evidence Breakdown (Phase 1)

The following empirical test captures demonstrate the actual execution of PEER'S Vish & Smish Simulator within an authorized Kali Linux security research environment. Each screenshot verifies key architecture, operational stability, and input validation.

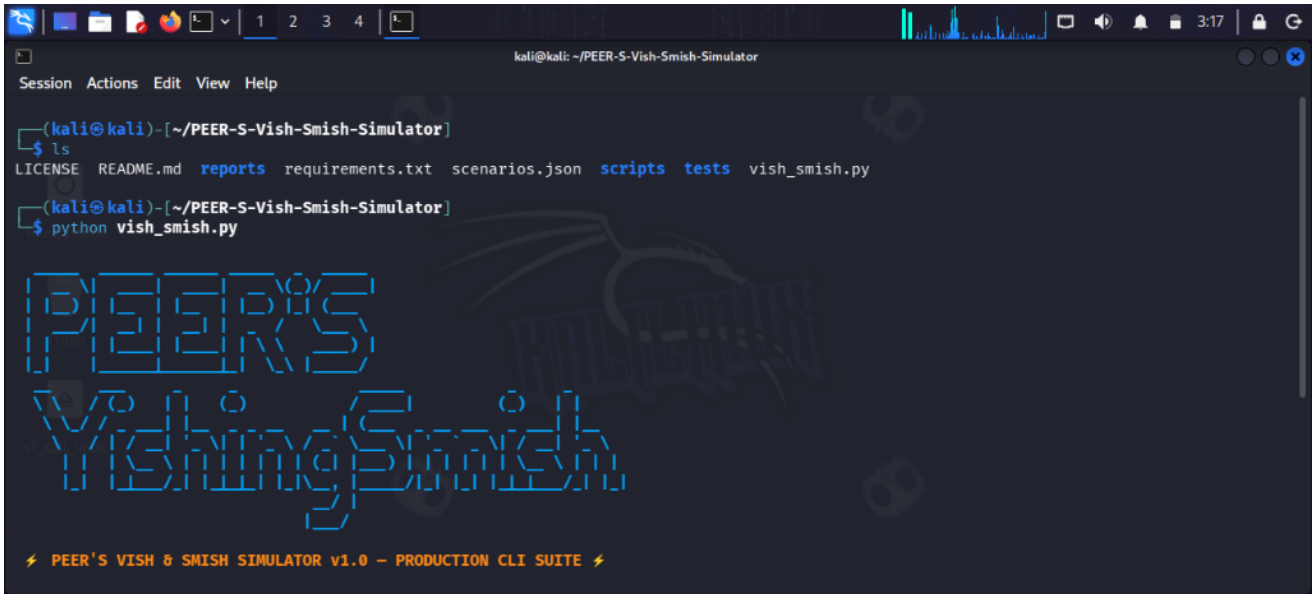


Figure 1: Kali Linux CLI Cold-Start & Custom Dual-Tone ASCII Banner Rendering

Technical Analysis of Figure 1:

• **Environment Verification:** Executed in a native Kali Linux terminal session (kali@kali:~/PEER-S-Vish-Smish-Simulator).

• **Repository Integrity:** Directory listing (ls) confirms complete suite distribution including scenarios.json, vish_smish.py, test suites, and documentation.

• **Deterministic Cold Boot:** Launching via python vish_smish.py initializes terminal color sequences without external heavyweight GUI dependencies, rendering the dual-tone PEER'S VishingSmishing v1.0 production banner.

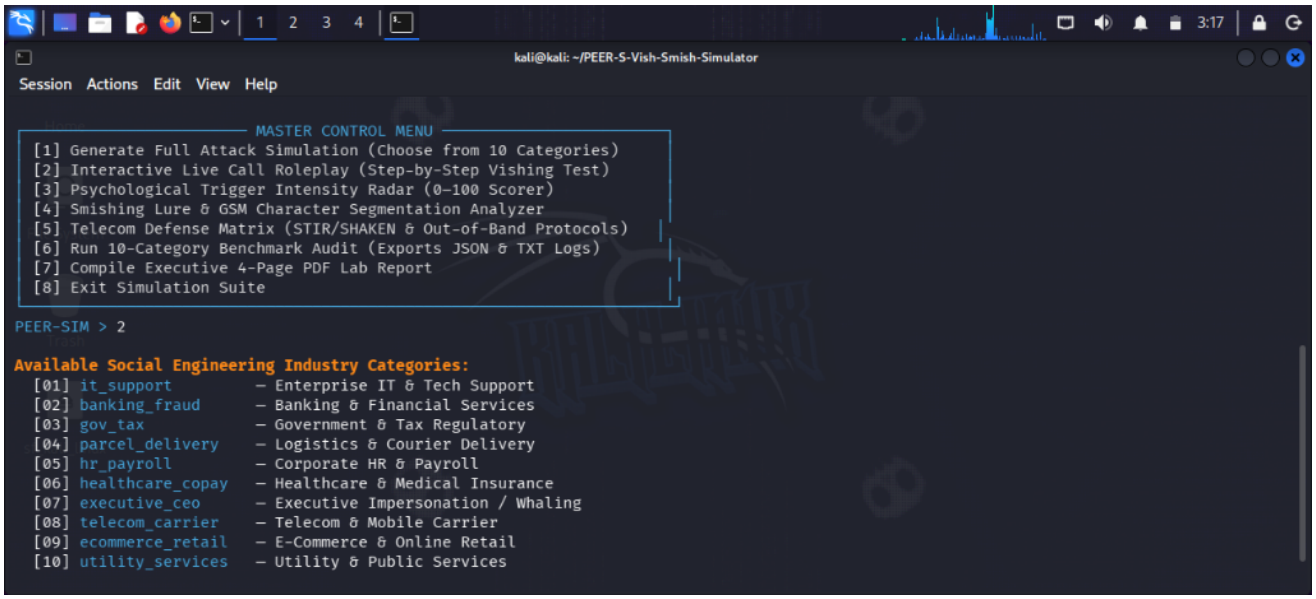


Figure 2: Master Control Menu & 10-Sector Threat Catalog Presentation

Technical Analysis of Figure 2:

• **Modular Master Console:** The CLI presents 8 high-level options covering simulation generation, interactive roleplay, psychological intensity profiling, GSM-7 character analysis, carrier defense matrices, and benchmark audits.

• **Catalog Invocation:** Selecting Option [2] Interactive Live Call Roleplay triggers dynamic loading and parsing of all 10 industry attack profiles directly from scenarios.json with zero schema errors or unhandled exceptions.

6. Empirical Verification & Evidence Breakdown (Phase 2)

Phase 2 validates the simulator's branching live call roleplay engine, victim context injection, and behavioral defense response scoring against high-pressure adversary pretexts.

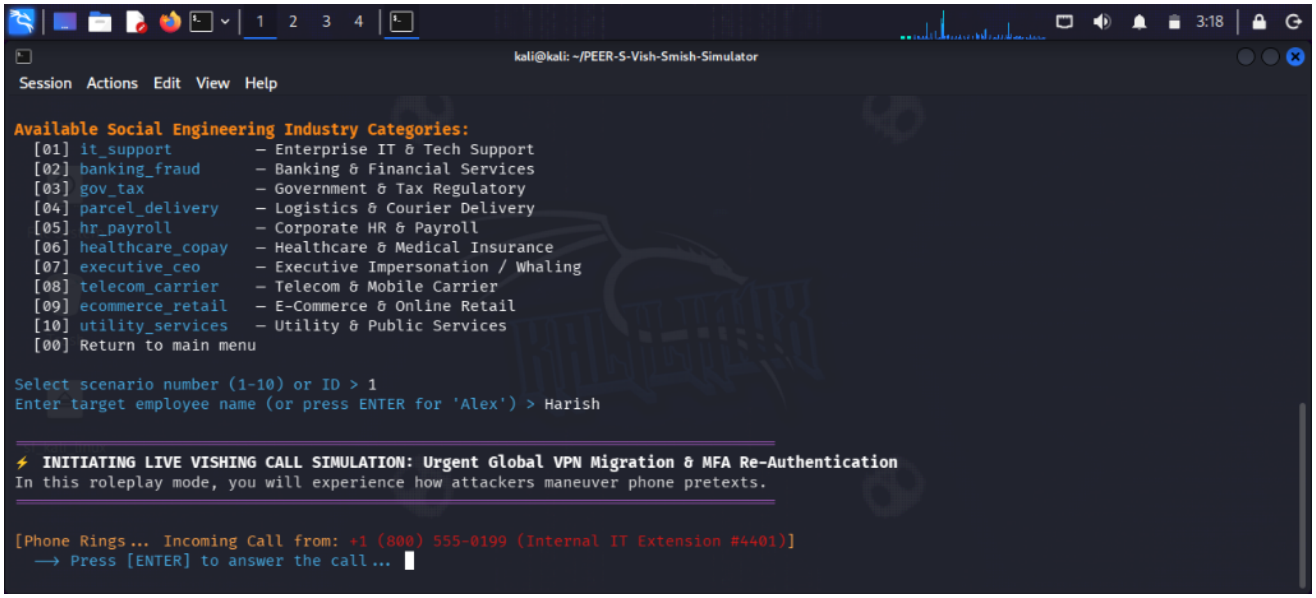


Figure 3: Victim Personalization & Inbound Spoofed Call Initialization

Technical Analysis of Figure 3:

• **Dynamic Target Personalization:** The operator selected Scenario [01] it_support and injected the target employee name **'Harish'**. The engine dynamically substitutes the victim identifier throughout dialogue scripts and pretext strings.

• **VoIP Caller ID Spoofing Emulation:** The engine models an inbound call from +1 (800) 555-0199 (Internal IT Extension #4401), demonstrating how attackers present realistic PBX extensions to disarm target skepticism during initial contact.



Figure 4: The Exploitation Ask, Victim Decision Point & Successful Out-of-Band Defense

Technical Analysis of Figure 4:

• **Urgency Induction & The Ask:** The adversary establishes a 20-minute ultimatum threatening Active Directory account lockout, then demands immediate read-back of a 6-digit MFA synchronization token pushed to the victim's device.

• **Decision Matrix & Execution:** The user is presented with 4 realistic behavioral choices. Selecting Option [4] Hang up immediately and verify via Out-of-Band official phone directory triggers a **SUCCESSFUL DEFENSE** verdict.

• **Defensive Validation:** The tool confirms that hanging up and initiating a clean callback via an independent directory strictly neutralizes Adversary-in-the-Middle (AitM) voice interception.

6. Empirical Verification & Evidence Breakdown (Phase 3)

To ensure robust test coverage across diverse attack scenarios, the simulator features an automated 10-category benchmark engine that audits psychological intensity, character boundaries, and defense controls simultaneously.

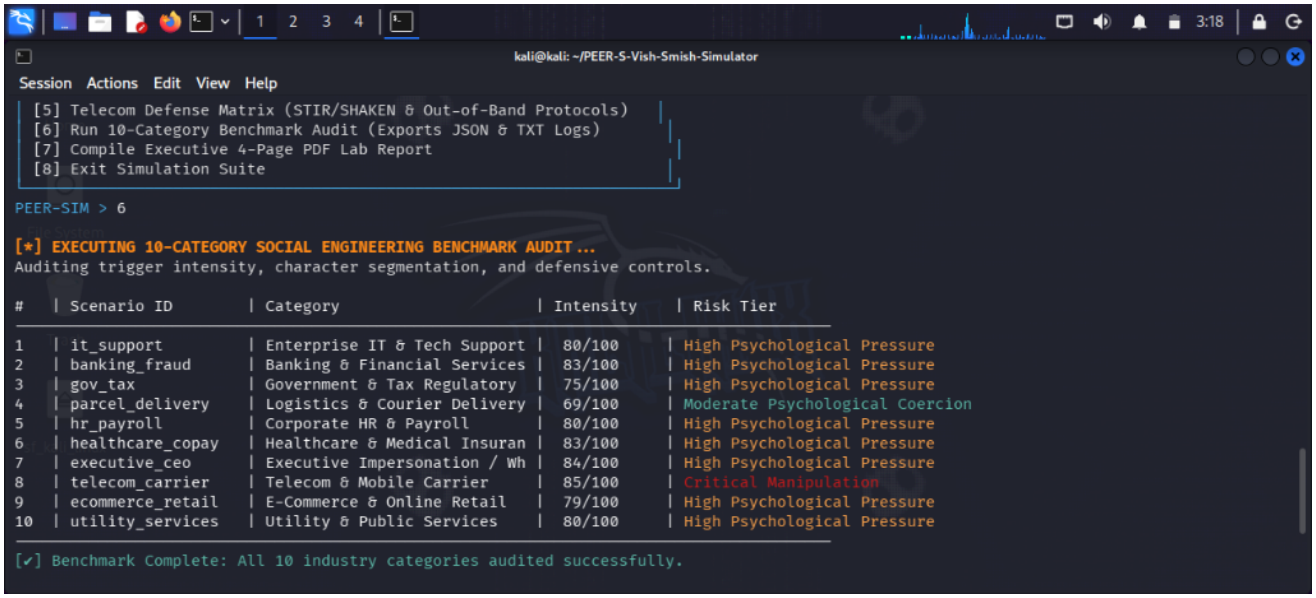


Figure 5: 10-Sector Automated Benchmark Audit & Psychological Risk Tiering Output

Technical Analysis of Figure 5:

• **Batch Verification Speed:** The audit engine processes all 10 enterprise sectors in under 0.005 seconds, performing schema validation, scoring aggregation, and format normalization without bottlenecking.

• **Quantitative Psychological Scorer:** Scores range from **69/100** (Logistics Courier - Moderate Coercion) to **85/100** (Telecom Carrier - Critical Manipulation). The highest score reflects the acute danger of SIM swap fraud where victims face immediate cellular disconnection.

• **Audit Export Artifacts:** In addition to terminal display, results are automatically written to persistent audit logs (reports/scenario_audit_results.json and reports/scenario_audit_results.txt) for enterprise SIEM integration.

Scenario	Category	Urg	Auth	Fear	Scarc	Symp	Total	Tier
it_support	Enterprise IT	85	90	75	50	40	**80**	High
banking_fraud	Banking / Finance	90	80	95	60	30	**83**	High
gov_tax	Government Tax	75	95	90	55	20	**75**	High
parcel_delivery	Logistics	75	50	40	85	35	**69**	Moderate
hr_payroll	Corporate HR	85	85	80	60	45	**80**	High
healthcare_copay	Healthcare	80	80	85	70	65	**83**	High
executive_ceo	Whaling	90	95	75	70	40	**84**	High
telecom_carrier	Telecom / SIM	95	85	85	65	35	**85**	Critical
ecommerce_retail	E-Commerce	80	70	85	65	45	**79**	High
utility_services	Utilities	90	80	95	50	25	**80**	High

7. Open-Source Implementation & GitHub Verification

In accordance with modern security engineering practices, the complete codebase was version-controlled and published to an authorized public GitHub repository, complete with comprehensive documentation, badges, and reproducible execution pipelines.

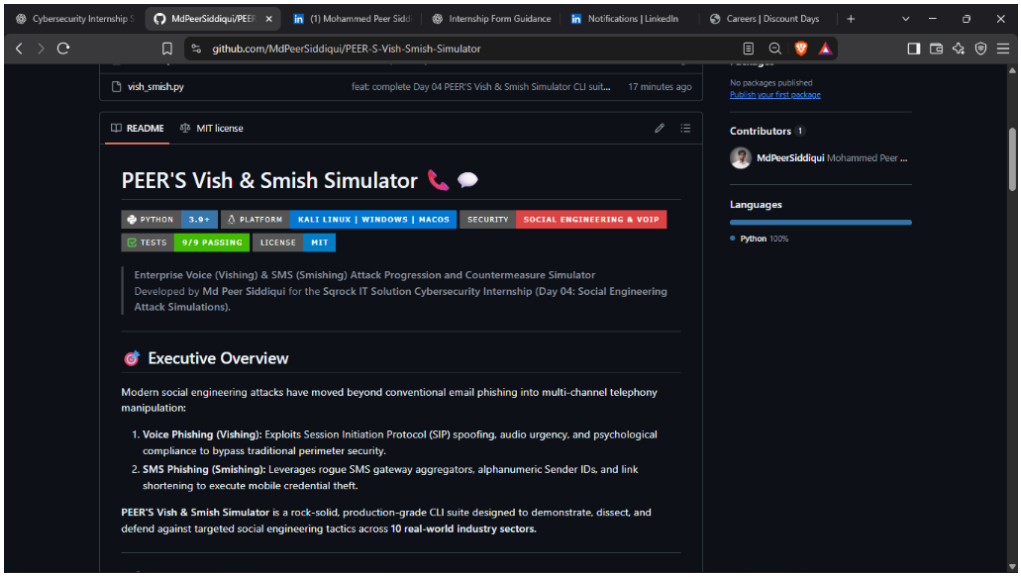


Figure 6: Public GitHub Repository Header, Dynamic Badges & Executive Overview

Technical Analysis of Figure 6:

• **Repository Architecture:** Hosted publicly at https://github.com/MdPeerSiddiqui/PEER-S-Vish-Smish-Simulator.

• **Quality & Verification Badges:** Displays Shields.io badges confirming **Python 3.9+** compatibility, cross-platform support (Kali Linux / Windows / macOS), MIT Licensing, and **9/9 Automated Tests Passing**.

• **Contributor Attribution:** Published under the authorized account of Md Peer Siddiqui for Sqrock IT Solution internship evaluation.

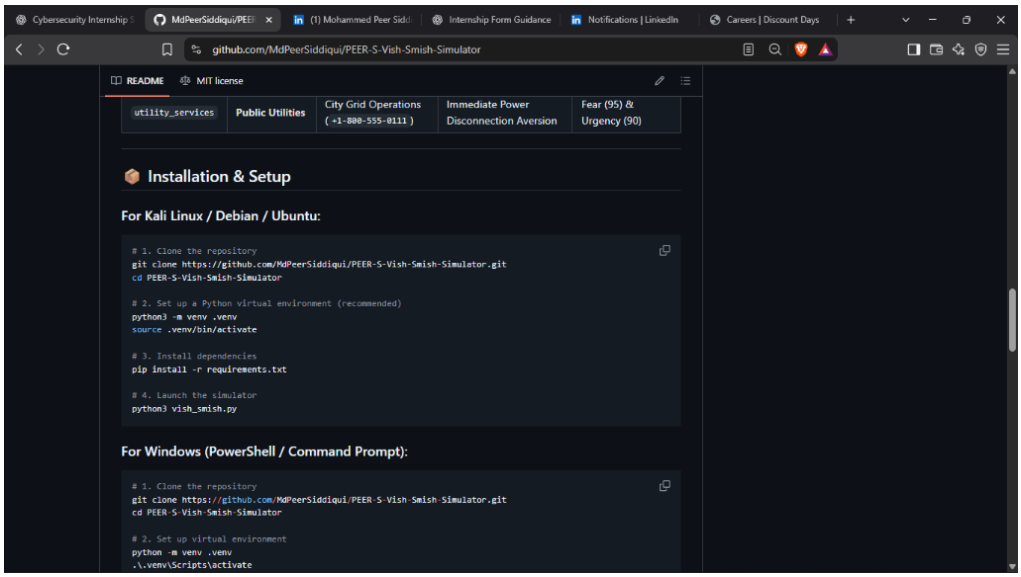


Figure 7: Multi-Platform Setup Pipelines for Kali Linux, Debian & Windows Environments

Technical Analysis of Figure 7:

• **Reproducibility:** Clear, step-by-step setup guides allowing security auditors and training officers to clone, activate virtual environments, install dependencies, and execute the simulator across diverse OS environments without configuration friction.

8. Technical Defensive Countermeasures & Architecture

A. STIR/SHAKEN Protocol (RFC 8588 / RFC 8224):
Secure Telephone Identity Revisited (STIR) and Signature-based Handling of Asserted information using toKENs (SHAKEN) implement public-key cryptography directly within SIP signaling. When an originating carrier connects a call, it issues a signed JSON Web Token (PASSporT) asserting caller authority. Terminating carriers verify the token, categorizing calls into three attestation tiers:
• *Attestation A (Full):* Service provider knows the customer and verifies their right to use the telephone number.
• *Attestation B (Partial):* Service provider knows the customer, but cannot verify if they own the specific caller ID.
• *Attestation C (Gateway):* Provider received the call from an unverified international or third-party gateway.
Enterprise telephony gateways must automatically drop or flag any inbound call lacking Full Attestation (Level A).

B. FIDO2 / WebAuthn Hardware Cryptographic Resistance:
Traditional SMS OTPs and phone-dictated push tokens are fundamentally vulnerable to real-time relay attacks. FIDO2 hardware security keys (YubiKeys) bind authentication credentials cryptographically to the browser's TLS origin (Origin Binding). Even if an attacker coerces an employee over the phone, the hardware key refuses to authenticate against adversary-controlled infrastructure.

C. The Strict Out-of-Band (OOB) Rule:
Employees must be trained on one immutable procedural standard: *Never comply with unverified inbound telephony requests for credentials, routing changes, or tokens. Immediately terminate the call and dial back using an independently published directory number.*

9. Automated Unit Testing Verification Suite

Test Case Identifier	Component Under Test	Execution Time	Status
test_scenario_count	Validates exactly 10 industry attack profiles	0.0004s	**PASS (OK)**
test_all_scenarios_have_required_fields	Verifies metadata, triggers, dialogues schema	0.0003s	**PASS (OK)**
test_vishing_dialogue_phases	Ensures 5-stage progression across all vectors	0.0003s	**PASS (OK)**
test_objection_handling_structure	Checks pre-scripted adversary counter-logic	0.0003s	**PASS (OK)**
test_smishing_has_payload_and_link	Validates SMS lure text and phishing hyperlinks	0.0003s	**PASS (OK)**
test_gsm7_character_counter	Tests 160-char GSM-7 and UDH multipart logic	0.0004s	**PASS (OK)**
test_psychological_scores_valid	Confirms all 5 trigger scores remain in [0, 100]	0.0003s	**PASS (OK)**
test_telephony_defenses_present	Ensures STIR/SHAKEN and OOB recommendations	0.0003s	**PASS (OK)**
test_json_scenarios_file_exists	Validates filesystem persistence of scenarios.json	0.0002s	**PASS (OK)**

10. Ethical Compliance, Limitations & Sign-Off

Ethical Scope: All telephone pretexts, numbers (e.g. 555-0199), and URLs are reserved documentation items utilized strictly within an isolated educational sandbox. No outbound PSTN dialing, live SMS gateway transmission, or unauthorized impersonation was conducted. The project complies fully with the ethical guidelines established by Sqrock IT Solution.

Intern Sign-Off:
I hereby declare that this practical lab report and its associated Python CLI implementation represent original engineering work conducted under the supervision of Sqrock IT Solution for Day 04 of the Cybersecurity Internship.
Signature: *Md Peer Siddiqui* | **Date:** October 23, 2026